

Excessive trust in client-side controls

Topic: Business Logic Vulnerabilities | Difficulty: Apprentice

Description

The application trusts the product price submitted by the client when adding items to the shopping cart. By intercepting the add-to-cart POST request and modifying the price parameter to an extremely low value an attacker can purchase high-value items at a fraction of their actual cost.

Steps to Exploit

1. Navigate to the product page for an expensive item (e.g., Lightweight l33t leather jacket - \$1337.00).
2. Click 'Add to cart' and intercept the POST request in Burp Suite.
3. Locate the 'price' parameter in the request body.
4. Change the price value to '1' (representing \$0.01).
5. Forward the modified request.
6. Proceed to checkout and complete the purchase at the manipulated price.

Proof of Concept

Original POST body:

```
productId=1&quantity=1&price=133700
```

Modified POST body:

```
productId=1&quantity=1&price=1
```

Result:

```
Item added to cart at $0.01 instead of $1337.00.
```

Impact

- Purchase of any product at an arbitrarily low price.
- Significant financial loss to the organization.
- Complete lack of server-side price integrity validation.
- Exploitable at scale for systematic financial fraud.

Mitigation / Remediation

1. Never trust client-supplied price data; always retrieve prices from the server-side database.
2. Validate cart contents and prices server-side before processing any payment.
3. Implement integrity checks comparing submitted prices against the product catalog.
4. Log and alert on discrepancies between client submissions and database price values.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

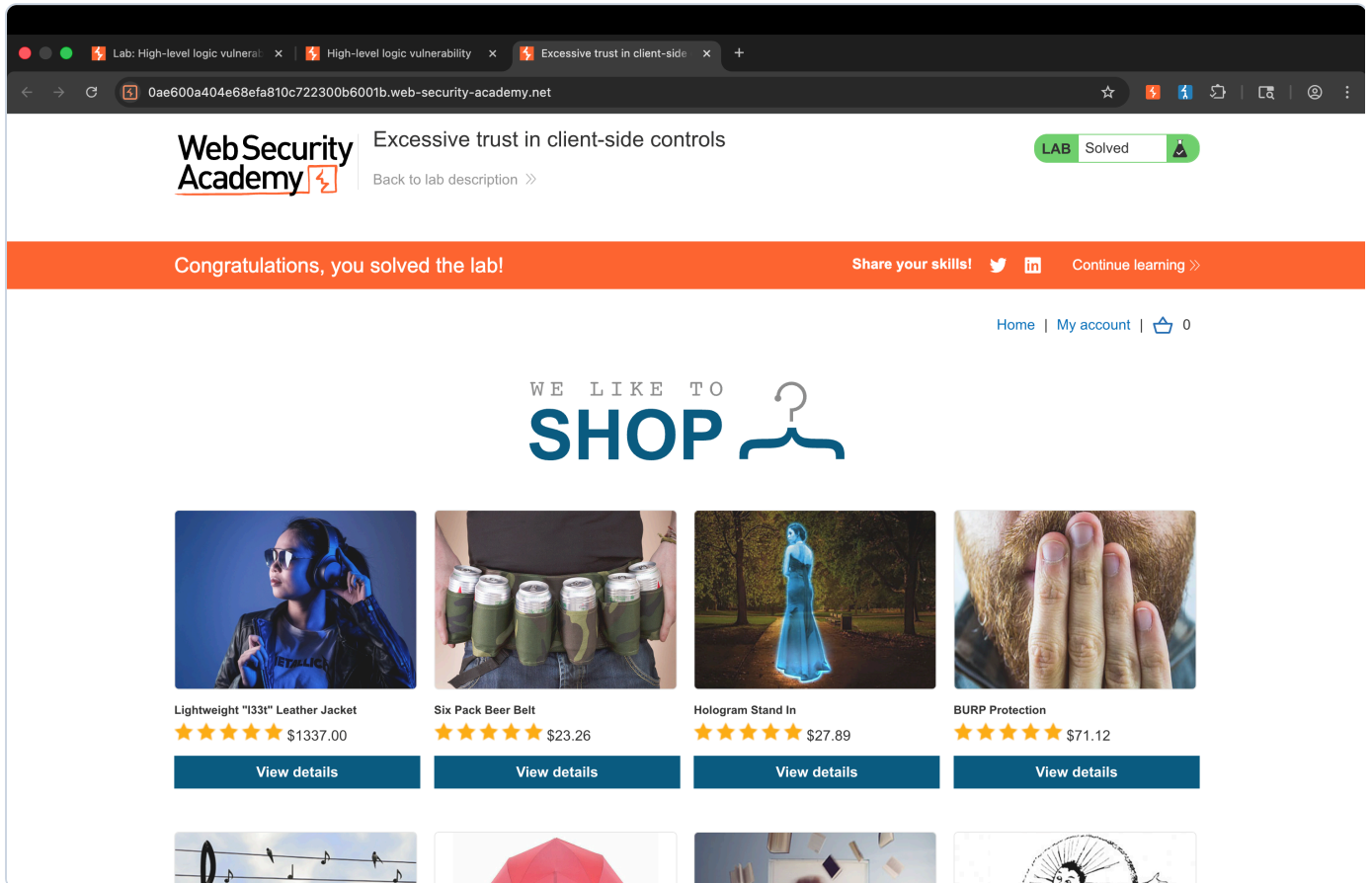
- Attack Vector: Network - HTTP parameter manipulation.
- Attack Complexity: Low - trivial single-parameter modification.
- Privileges Required: None.
- User Interaction: None.
- Integrity: High - financial data integrity compromised.
- Confidentiality / Availability: None.

BizLogic ClientSide Price

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.